



Governança em Infraestruturas Complexas

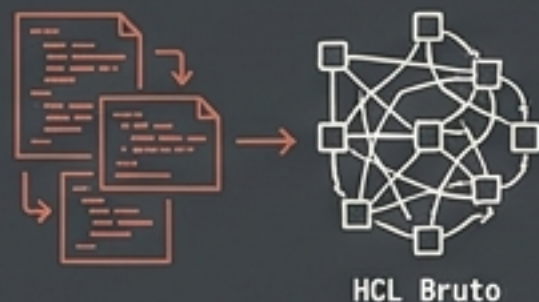
Expandindo a Plataforma IaC com
Golden Paths e Soberania Externa

[Arquitetura de Referência & Casos de Uso Avançados]

O Paradigma Antigo



- Caos de código HCL bruto e complexidade exposta.



- Revisão manual de segurança atuando como gargalo.

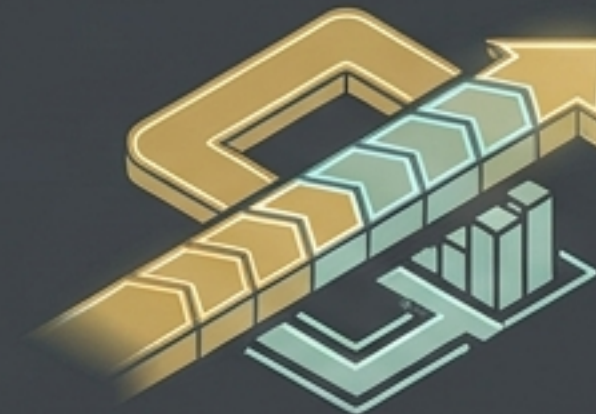


- Foco em reparar casos atípicos que quebram pipelines.



TRANSFORMAÇÃO:
CÓDIGO -> PRODUTO INTERNO

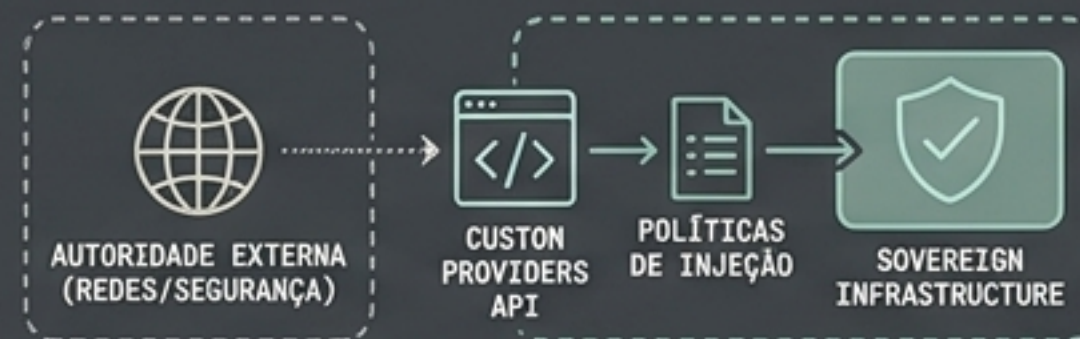
Plataforma Moderna



- **Golden Paths (Módulos Privados):** Ocultam a complexidade, reduzem a carga cognitiva e forçam padrões pré-aprovados.

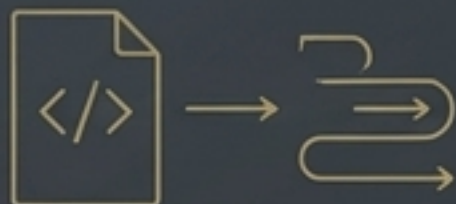


- **Sovereign Infrastructure (Custom Providers):** Mantêm a autoridade externa (Redes/Segurança) via APIs e injeção de políticas.



0 Motor de Governança

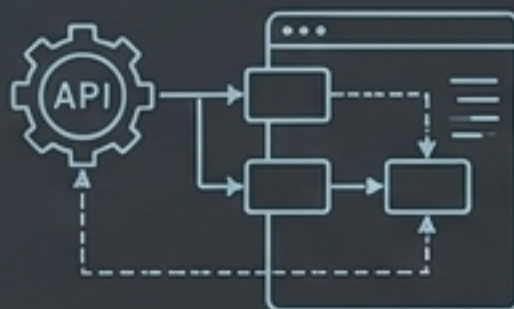
Passo 1: Código (Consumo)



Passo 1: Código (Consumo)

Desenvolvedor consome um Golden Path simples.

Passo 2: Plan Modification

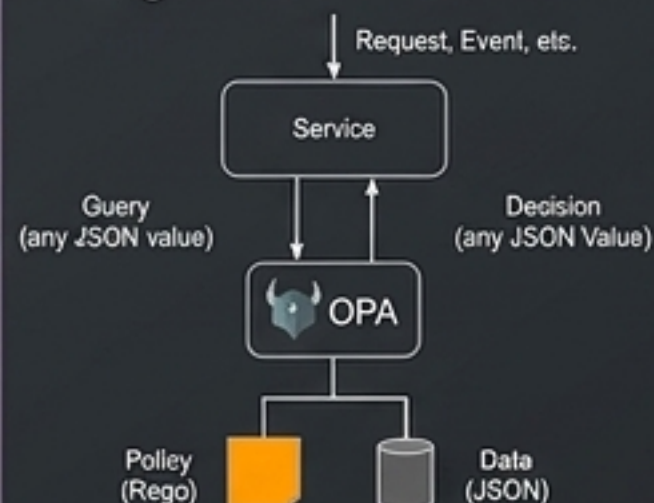


Passo 2: Plan Modification

O Custom Provider consulta APIs externas e ajusta parâmetros de forma invisível.

Passo 3: Plan-Based Scanning (OPA/Rego)

A avaliação ocorre no arquivo JSON do Plano (que resolve blocos dinâmicos), não no código estático.



Passo 4: Graph Analysis



Passo 4: Graph Analysis

O plano é injetado em um grafo para validação de relacionamentos e prevenção de ataques.

A verdadeira segurança IaC atua no estado final computado.

Mapeamento de Novos Recursos Gerenciáveis

Recurso	Estratégia de Gerenciamento	Regra de Governança Injetada
 Subnets	Custom Provider / API de Redes	[AUTO-PROVISIONAMENTO] Consulta ao IPAM para alocar faixas de IP (CIDR) baseadas em região/ambiente, evitando sobreposição.
 Security Groups (SG)	Golden Paths / OPA	[BLOQUEIO IMEDIATO] Regras com 0.0.0.0/0 em portas sensíveis (ex: 22, 3389) são rejeitadas. Força referência a outros SGs.
 IAM (Roles/Policies)	Custom Provider / Plan Modification	[LIMITAÇÃO DE ESCOPO] Princípio do Menor Privilégio com injeção de Permissions Boundaries, sobrepondo tentativas de privilégio Admin.
 KMS (Chaves)	Golden Paths	[ROTAÇÃO ATIVA] Rotação automática habilitada por padrão; políticas restritas estritamente ao workload específico.

Caso de Uso A: Networking Sem Atrito

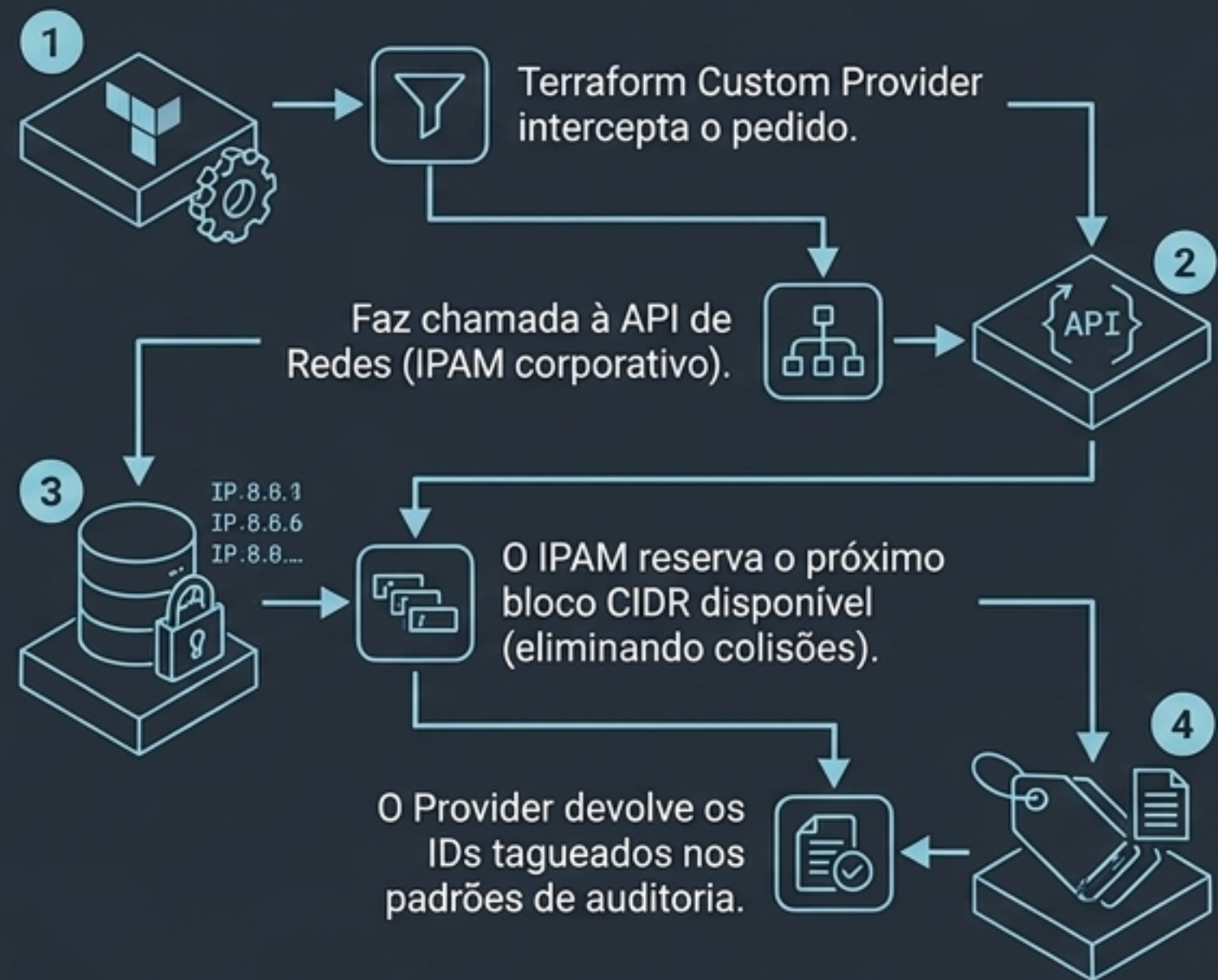
A Experiência do Dev (Fricção Zero)

```
module "network" {  
  type = "App Subnet"  
}
```



Resultado mental: A rede simplesmente existe.

A Lógica da Plataforma (Soberania)



Caso de Uso B: Segurança de Perímetro Blindada

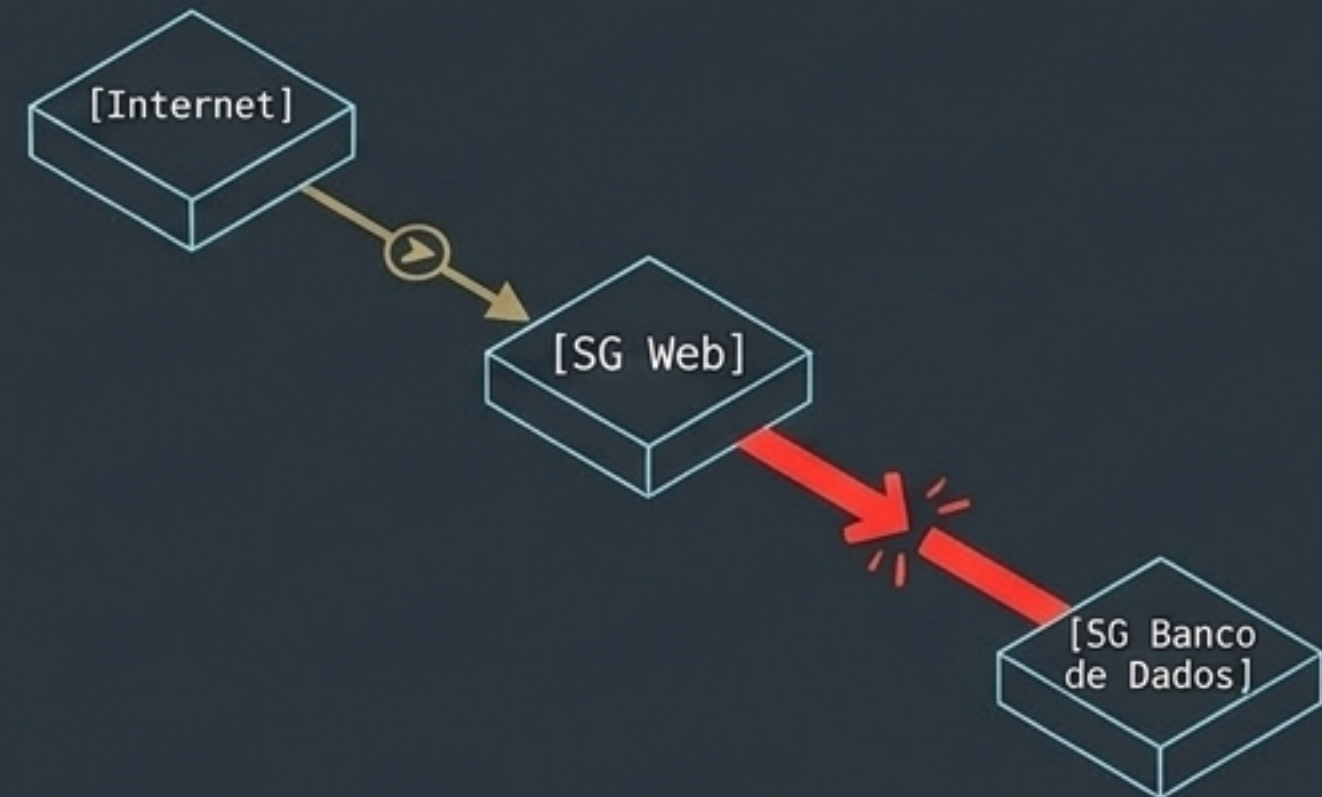
Prevenção Preventiva (Plan-based OPA)



[DROP: SSH da Internet]

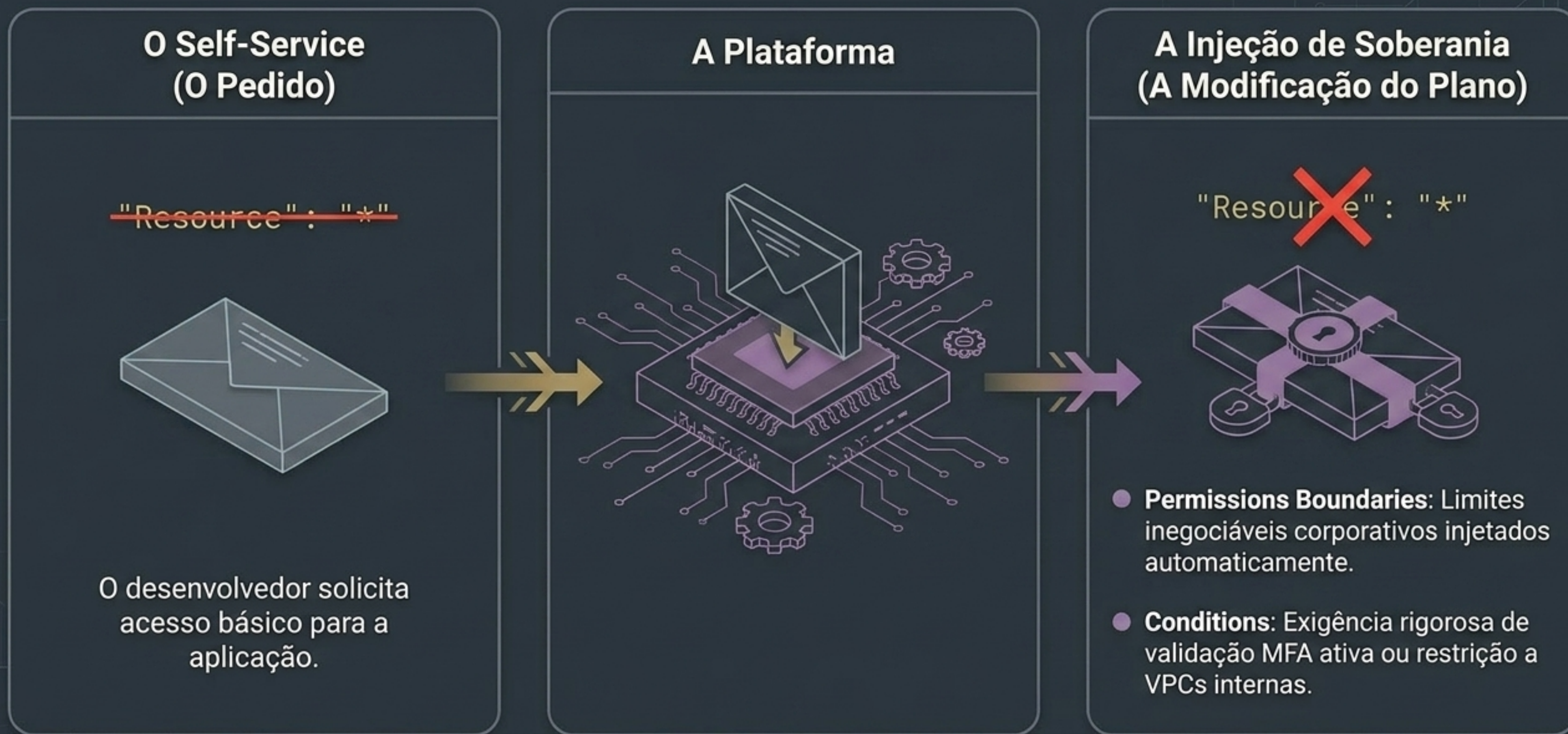
A análise estrita do arquivo JSON paralisa o deploy caso detecte portas sensíveis abertas para a internet, atuando antes da criação do recurso.

Contexto Lateral (Graph Analysis)

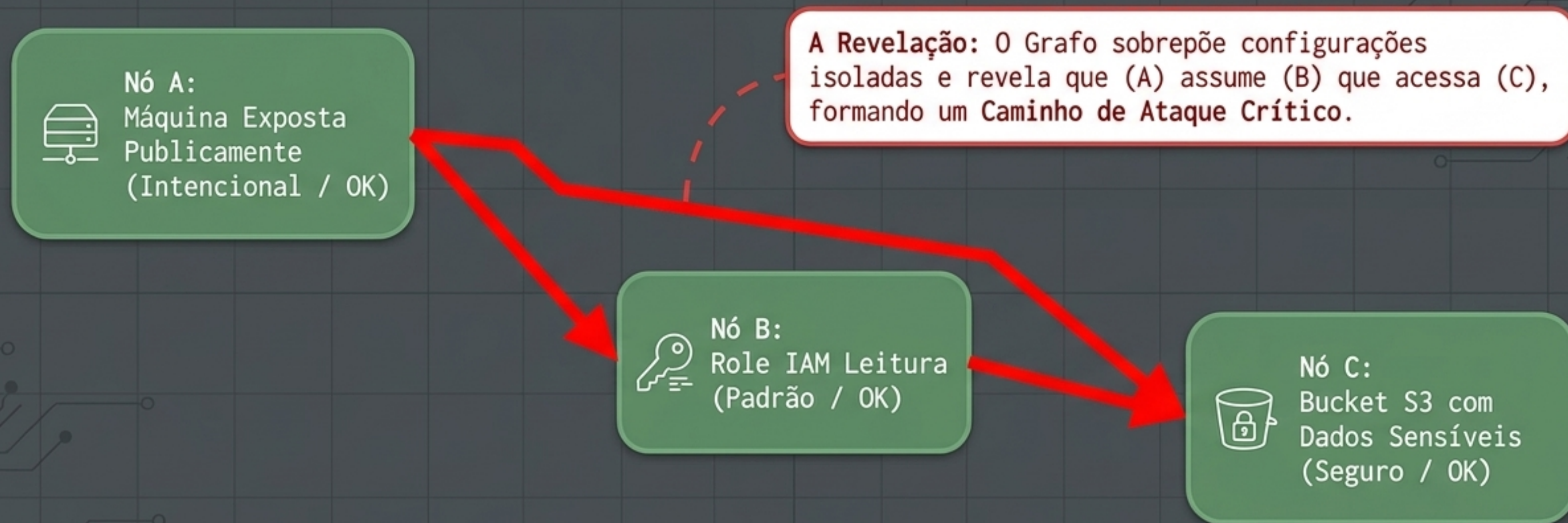


O sistema mapeia topologias reais para impedir que um Security Group mal configurado crie um caminho de ataque lateral direto para dados sensíveis em outra sub-rede.

Caso de Uso C: Identidade e Acesso Soberano (IAM)



0 Porquê da Análise de Grafos (Visão de Ataque)



**Checar configurações isoladas não é suficiente.
A segurança real exige mapear as relações sistêmicas.**

A Matriz de Soberania (Orquestrando a Empresa)



A arquitetura está mapeada. Qual é o seu próximo passo operacional?



Especificação Técnica: Provedor Customizado de Redes

Desenhar os contratos de API, a lógica de Plan Modification e os parâmetros do bloco de IPs para o time de Redes.



Codificação de Políticas: Regras OPA / IAM

Escrever e validar o conjunto de regras Rego para varredura de Security Groups, portas expostas e injeção de limites IAM em tempo real.

AGUARDANDO INSTRUÇÃO DO USUÁRIO_█